

NIST SP 800-53 Rev 5 control PM-4 (Plan of Action and Milestones Process) is assessed by examining, interviewing, and testing: PM-4 · Plan of Action and Milestones Process Control Statement: a. Implement a process to ensure that plans of action and milestones for the information security, privacy, and supply chain risk management programs and associated organizational systems: 1. Are developed and maintained; 2. Document the remedial information security, privacy, and supply chain risk management actions to adequately respond to risk to organizational operations and assets, individuals, other organizations, and the

NIST SP 800-53 Rev 5 control PM-32 (Purposing) is assessed by examining, interviewing, and testing: PM-32 · Purposing Control Statement: Analyze [organization-defined parameter] supporting mission essential services or functions to ensure that the information resources are being used consistent with their intended purpose. Supplemental Guidance: Analyze [organization-defined parameter] supporting mission essential services or functions to ensure that the information resources are being used consistent with their intended purpose. Systems are designed to support a specific mission or business

Control PM-18: ·s privacy program. Program management controls are distinct from common, system-specific, and hybrid controls because program management controls are independent of any particular information system. Together, the privacy plans for individual systems and the organization-wide privacy program plan provide complete coverage for the privacy controls employed within the organization. Common controls are documented in an appendix to the organization-s privacy program plan unless the controls are included in a separate privacy plan for a system. The organization-wide privacy program plan indicates which separate privacy plans contain descriptions of privacy controls. Related Controls: PM-8, PM-9, PM-19. Control Enhancements: None. References: [PRIVACT], [OMB A-130].

NIST SP 800-53 Rev 5 control PM-5 (System Inventory): PM-5 · System Inventory Control Statement: Develop and update [organization-defined parameter] an inventory of organizational systems. Supplemental Guidance: Develop and update [organization-defined parameter] an inventory of organizational systems. [OMB A-130](#27847491-5ce1-4f6a-a1e4-9e483782f0ef) provides guidance on developing systems inventories and associated reporting requirements. System

NIST SP 800-53 Rev 5 control PM-20 (Dissemination of Privacy Program Information) summarizes the requirements for this control: PM-20 · Dissemination of Privacy Program Information Control Statement: Maintain a central resource webpage on the organization-s principal public website that serves as a central source of information about the organization-s privacy program and that: a. Ensures that the public has access to information about organizational privacy activities and can communicate with its senior agency official for privacy; b. Ensures that organizational privacy practices and reports are publicly available; and

NIST SP 800-53 Rev 5 control PM-27 (Privacy Reporting) is assessed by examining, interviewing, and testing: PM-27 · Privacy Reporting Control Statement: a. Develop [organization-defined parameter] and disseminate to: 1. [organization-defined parameter] to demonstrate accountability with statutory, regulatory, and policy privacy mandates; and 2. [organization-defined parameter] and other personnel with responsibility for monitoring privacy program compliance; and b. Review and update privacy reports [organization-defined parameter]. Supplemental Guidance: a. Develop [organization-defined paramete

NIST SP 800-53 Rev 5 control PM-9 (Risk Management Strategy) is assessed by examining, interviewing, and testing: PM-9 · Risk Management Strategy Control Statement: a. Develops a comprehensive strategy to manage: 1. Security risk to organizational operations and assets, individuals, other organizations, and the Nation associated with the operation and use of organizational systems; and 2. Privacy risk to individuals resulting from the authorized processing of personally identifiable information; b. Implement the risk management strategy consistently across the organization; and c. Review and update the

NIST SP 800-53 Rev 5 control PM-11 (Mission and Business Process Definition) is assessed by examining, interviewing, and testing: PM-11 · Mission and Business Process Definition Control Statement: a. Define organizational mission and business processes with consideration for information security and privacy and the resulting risk to organizational operations, organizational

assets, individuals, other organizations, and the Nation; and b. Determine information protection and personally identifiable information processing needs arising from the defined mission and business processes; and c. Review and revise the mission and

NIST SP 800-53 Rev 5 control PM-29 (Risk Management Program Leadership Roles) is defined as follows: PM-29 · Risk Management Program Leadership Roles Control Statement: a. Appoint a Senior Accountable Official for Risk Management to align organizational information security and privacy management processes with strategic, operational, and budgetary planning processes; and b. Establish a Risk Executive (function) to view and analyze risk from an organization-wide perspective and ensure management of risk is consistent across the organization. Supplemental Guidance: a. Appoint a Senior Accountable Official for Risk Management to align organizational information security and privacy management

NIST SP 800-53 Rev 5 control PM-30 (Supply Chain Risk Management Strategy) is assessed by examining, interviewing, and testing: PM-30 · Supply Chain Risk Management Strategy Control Statement: a. Develop an organization-wide strategy for managing supply chain risks associated with the development, acquisition, maintenance, and disposal of systems, system components, and system services; b. Implement the supply chain risk management strategy consistently across the organization; and c. Review and update the supply chain risk management strategy on [organization-defined parameter] or as required, to address organizational

NIST SP 800-53 Rev 5 control PM-8 (Critical Infrastructure Plan) is assessed by examining, interviewing, and testing: PM-8 · Critical Infrastructure Plan Control Statement: Address information security and privacy issues in the development, documentation, and updating of a critical infrastructure and key resources protection plan. Supplemental Guidance: Address information security and privacy issues in the development, documentation, and updating of a critical infrastructure and key resources protection plan. Protection strategies are based on the prioritization of critical assets and resources. The requirem

From the NIST SP 800-172 Rev 3 Final Public Draft: ADVERSARY EFFECTS 1645 P reclude (Negate), Impede (Exert), Expose (Detect) REFERENCES Source Controls: PM-16(01) 3.12 . Security Assessment and Monitoring 03.1 2.01E P enetration Testing Conduct penetration testing [Assignment: organization-defined frequency] on [Assignment: organization-defined systems or system components]. DISCUSSION Penetration testing is a specialized type of assessment conducted on systems or system components to identify vulnerabilities that could be exploited by adversaries. It is conducted by penetration testing agents and teams with particular skills and experience that include technical expertise in network, operating system, and application-level security. Penetration testing can be used to validate vulnerabilities or to determine a system's penet

PM-2 · Information Security Program Leadership Role Control Statement: Appoint a senior agency information security officer with the mission and resources to coordinate, develop, implement, and maintain an organization-wide information security program. Supplemental Guidance: Appoint a senior agency information security officer with the mission and resources to coordinate, develop, implement, and maintain an organization-wide information security program. The senior agency information security officer is an organizational official. For federal agencies (as defined by applicable laws, executive orders, regulations, directives, policies, and standards), this official is the senior agency information security officer. Organizations may also refer to this official as the senior information security officer or chief information security officer.

NIST SP 800-53 Rev 5 control PM-5 (System Inventory) summarizes the requirements for this control: PM-5 · System Inventory Control Statement: Develop and update [organization-defined parameter] an inventory of organizational systems. Supplemental Guidance: Develop and update [organization-defined parameter] an inventory of organizational systems. [OMB A-130](#27847491-5ce1-4f6a-a1e4-9e483782f0ef) provides guidance on developing systems inventories and associated reporting requirements. System inventory refers to an organization-wide inventory of systems, not system components as described i

NIST SP 800-53 Rev 5 control PM-13 (Security and Privacy Workforce): PM-13 · Security and Privacy Workforce Control Statement: Establish a security and privacy workforce development and improvement program. Supplemental Guidance: Establish a security and privacy workforce development and

improvement program. Security and privacy workforce development and improvement programs include defining the knowledge, skills, and abilities needed to perform security and privacy

NIST SP 800-53 Rev 5 control PM-25 (Minimization of Personally Identifiable Information Used in Testing, Training, and Research) summarizes the requirements for this control: PM-25 · Minimization of Personally Identifiable Information Used in Testing, Training, and Research Control Statement: a. Develop, document, and implement policies and procedures that address the use of personally identifiable information for internal testing, training, and research; b. Limit or minimize the amount of personally identifiable information used for internal testing, training, and research purposes; c. Authorize the use of personally identifiable information when such information is

NIST SP 800-53 Rev 5 control PM-6 (Measures of Performance) is assessed by examining, interviewing, and testing: PM-6 · Measures of Performance Control Statement: Develop, monitor, and report on the results of information security and privacy measures of performance. Supplemental Guidance: Develop, monitor, and report on the results of information security and privacy measures of performance. Measures of performance are outcome-based metrics used by an organization to measure the effectiveness or efficiency of the information security and privacy programs and the controls employed in support of the program

PM-23 · Data Governance Body Control Statement: Establish a Data Governance Body consisting of [organization-defined parameter] with [organization-defined parameter]. Supplemental Guidance: Establish a Data Governance Body consisting of [organization-defined parameter] with [organization-defined parameter]. A Data Governance Body can help ensure that the organization has coherent policies and the ability to balance the utility of data with security and privacy requirements. The Data Governance Body establishes policies, procedures, and standards that facilitate data governance so that data, including personally identifiable information, is effectively managed and maintained in accordance with applicable laws, executive orders, directives, regulations, policies, standards, and guidance. Responsibilities can include developing and implementing guidelines that support data modeling, quality, integrity, and the de-identification needs of personally identifiable information across the information life cycle as well as reviewing and approving applications to release data outside of the organization, archiving the applications and the released data, and performing post-release monitoring to ensure that the assumptions made as part of the data release continue to be valid. Members include the chief information officer, senior agency information security officer, and senior agency official for privacy. Federal agencies are required to establish a Data Governance Body with specific roles and responsibilities in accordance with the [EVIDACT](#511da9ca-604d-43f7-be41-b862085420a9) and policies set forth under [OMB M-19-23](#d886c141-c832-4ad7-ac6d-4b94f4b550d3).

NIST SP 800-53 Rev 5 control PM-7 (Enterprise Architecture) is assessed by examining, interviewing, and testing: PM-7 · Enterprise Architecture Control Statement: Develop and maintain an enterprise architecture with consideration for information security, privacy, and the resulting risk to organizational operations and assets, individuals, other organizations, and the Nation. Supplemental Guidance: Develop and maintain an enterprise architecture with consideration for information security, privacy, and the resulting risk to organizational operations and assets, individuals, other organizations, and the Nation

NIST SP 800-53 Rev 5 control PM-24 (Data Integrity Board) is assessed by examining, interviewing, and testing: PM-24 · Data Integrity Board Control Statement: Establish a Data Integrity Board to: a. Review proposals to conduct or participate in a matching program; and b. Conduct an annual review of all matching programs in which the agency has participated. Supplemental Guidance: Establish a Data Integrity Board to: a. Review proposals to conduct or participate in a matching program; and b. Conduct an annual review of all matching programs in which the agency has participated. A Data Integrity Board is

NIST SP 800-53 Rev 5 control PM-30 (Supply Chain Risk Management Strategy): PM-30 · Supply Chain Risk Management Strategy Control Statement: a. Develop an organization-wide strategy for managing supply chain risks associated with the development, acquisition, maintenance, and disposal of systems, system components, and system services; b. Implement the supply chain risk management strategy consistently across the organization; and c. Review and update the supply chain risk

NIST SP 800-53 Rev 5 control PM-5.1 (Inventory of Personally Identifiable Information) is assessed by examining, interviewing, and testing: PM-5.1 · Inventory of Personally Identifiable Information Control Statement: Establish, maintain, and update [organization-defined parameter] an inventory of all systems, applications, and projects that process personally identifiable information. Supplemental Guidance: Establish, maintain, and update [organization-defined parameter] an inventory of all systems, applications, and projects that process personally identifiable information. An inventory of systems, applications, and projects that

NIST SP 800-53 Rev 5 control PM-30.1 (Suppliers of Critical or Mission-essential Items) summarizes the requirements for this control: PM-30.1 · Suppliers of Critical or Mission-essential Items Control Statement: Identify, prioritize, and assess suppliers of critical or mission-essential technologies, products, and services. Supplemental Guidance: Identify, prioritize, and assess suppliers of critical or mission-essential technologies, products, and services. The identification and prioritization of suppliers of critical or mission-essential technologies, products, and services is paramount to the mission/business success of

PM-13 · Security and Privacy Workforce Control Statement: Establish a security and privacy workforce development and improvement program. Supplemental Guidance: Establish a security and privacy workforce development and improvement program. Security and privacy workforce development and improvement programs include defining the knowledge, skills, and abilities needed to perform security and privacy duties and tasks; developing role-based training programs for individuals assigned security and privacy roles and responsibilities; and providing standards and guidelines for measuring and building individual qualifications for incumbents and applicants for security- and privacy-related positions. Such workforce development and improvement programs can also include security and privacy career paths to encourage security and privacy professionals to advance in the field and fill positions with greater responsibility. The programs encourage organizations to fill security- and privacy-related positions with qualified personnel. Security and privacy workforce development and improvement programs are complementary to organizational security awareness and training programs and focus on developing and institutionalizing the core security and privacy capabilities of personnel needed to protect organizational operations, assets, and individuals.

PM-14 · Testing, Training, and Monitoring Control Statement: a. Implement a process for ensuring that organizational plans for conducting security and privacy testing, training, and monitoring activities associated with organizational systems: 1. Are developed and maintained; and 2. Continue to be executed; and b. Review testing, training, and monitoring plans for consistency with the organizational risk management strategy and organization-wide priorities for risk response actions. Supplemental Guidance: a. Implement a process for ensuring that organizational plans for conducting security and privacy testing, training, and monitoring activities associated with organizational systems: 1. Are developed and maintained; and 2. Continue to be executed; and b. Review testing, training, and monitoring plans for consistency with the organizational risk management strategy and organization-wide priorities for risk response actions. A process for organization-wide security and privacy testing, training, and monitoring helps ensure that organizations provide oversight for testing, training, and monitoring activities and that those activities are coordinated. With the growing importance of continuous monitoring programs, the implementation of information security and privacy across the three levels of the risk management hierarchy and the widespread use of common controls, organizations coordinate and consolidate the testing and monitoring activities that are routinely conducted as part of ongoing assessments supporting a variety of controls. Security and privacy training activities, while focused on individual systems and specific roles, require coordination across all organizational elements. Testing, training, and monitoring plans and activities are informed by current threat and vulnerability assessments.

NIST SP 800-53 Rev 5 control PM-10 (Authorization Process) is assessed by examining, interviewing, and testing: PM-10 · Authorization Process Control Statement: a. Manage the security and privacy state of organizational systems and the environments in which those systems operate through authorization processes; b. Designate individuals to fulfill specific roles and responsibilities within the organizational risk management process; and c. Integrate the authorization processes into an organization-wide risk management program. Supplemental Guidance: a. Manage the security and privacy state of organization

PM-29 · Risk Management Program Leadership Roles Control Statement: a. Appoint a Senior Accountable Official for Risk Management to align organizational information security and privacy management processes with strategic, operational, and budgetary planning processes; and b. Establish a Risk Executive (function) to view and analyze risk from an organization-wide perspective and ensure management of risk is consistent across the organization. Supplemental Guidance: a. Appoint a Senior Accountable Official for Risk Management to align organizational information security and privacy management processes with strategic, operational, and budgetary planning processes; and b. Establish a Risk Executive (function) to view and analyze risk from an organization-wide perspective and ensure management of risk is consistent across the organization. The senior accountable official for risk management leads the risk executive (function) in organization-wide risk management activities.

NIST SP 800-53 Rev 5 control PM-24 (Data Integrity Board) summarizes the requirements for this control: PM-24 · Data Integrity Board Control Statement: Establish a Data Integrity Board to: a. Review proposals to conduct or participate in a matching program; and b. Conduct an annual review of all matching programs in which the agency has participated. Supplemental Guidance: Establish a Data Integrity Board to: a. Review proposals to conduct or participate in a matching program; and b. Conduct an annual review of all matching programs in which the agency has participated. A Data Integrity Board is

Control PM-8: CRITICAL INFRASTRUCTURE PLAN Control: Address information security and privacy issues in the development, documentation, and updating of a critical infrastructure and key resources protection plan. Discussion: Protection strategies are based on the prioritization of critical assets and resources. The requirement and guidance for defining critical infrastructure and key resources and for preparing an associated critical infrastructure protection plan are found in applicable laws, executive orders, directives, policies, regulations, standards, and guidelines. Related Controls: CP-2, CP-4, PE-18, PL-2, PM-9, PM-11, PM-18, RA-3, SI-12. Control Enhancements: None. References: [EO 13636], [OMB A-130], [HSPD 7], [DHS NIPP].

and b. Review and update the policy and procedures [Assignment: organization-defined frequency]. Discussion: Controlled unclassified information is defined by the National Archives and Records Administration along with the safeguarding and dissemination requirements for such information and is codified in [32 CFR 2002] and, specifically for systems external to the federal organization, 32 CFR 2002.14h. The policy prescribes the specific use and conditions to be implemented in accordance with organizational procedures, including via its contracting processes. Related Controls: CA-6, PM-10. Control Enhancements: None. References: [32 CFR 2002], [SP 800-171], [SP 800-172], [NARA CUI].

NIST SP 800-53 Rev 5 control PM-17 (Protecting Controlled Unclassified Information on External Systems) summarizes the requirements for this control: PM-17 · Protecting Controlled Unclassified Information on External Systems Control Statement: a. Establish policy and procedures to ensure that requirements for the protection of controlled unclassified information that is processed, stored or transmitted on external systems, are implemented in accordance with applicable laws, executive orders, directives, policies, regulations, and standards; and b. Review and update the policy and procedures [organization-defined parameter]. Supplemental Gui

NIST SP 800-53 Rev 5 control PM-7 (Enterprise Architecture) summarizes the requirements for this control: PM-7 · Enterprise Architecture Control Statement: Develop and maintain an enterprise architecture with consideration for information security, privacy, and the resulting risk to organizational operations and assets, individuals, other organizations, and the Nation. Supplemental Guidance: Develop and maintain an enterprise architecture with consideration for information security, privacy, and the resulting risk to organizational operations and assets, individuals, other organizations, and the N

NIST SP 800-53 Rev 5 control PM-15 (Security and Privacy Groups and Associations) is assessed by examining, interviewing, and testing: PM-15 · Security and Privacy Groups and Associations Control Statement: Establish and institutionalize contact with selected groups and associations within the security and privacy communities: a. To facilitate ongoing security and privacy education and training for organizational personnel; b. To maintain currency with recommended security and privacy practices, techniques, and technologies; and c. To share current security and privacy information,

including threats, vulnerabilities, and incid

agencies should consult with their senior agency official for privacy and legal counsel on this requirement and be aware of the statutory exceptions and OMB guidance relating to the provision. Organizations can use any system for keeping notations of disclosures, if it can construct from such a system, a document listing of all disclosures along with the required information. Automated mechanisms can be used by organizations to determine when personally identifiable information is disclosed, including commercial services that provide notifications and alerts. Accounting of disclosures may also be used to help organizations verify compliance with applicable privacy statutes and policies governing the disclosure or dissemination of information and dissemination restrictions. Related Controls: AC-3, AU-2, PT-2. Control Enhancements: None. References: [PRIVACT], [OMB A-130].

Control PM-32: si publication is a vaillabefreeofchargefrom:ht  
tps://doi.org/10.6028/NIST.SP.800-53r5. I NIST SP 800-53, REV. 5  
SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

TABLE C-14: PERSONNEL SECURITY FAMILY CONTROL NUMBER CONTROL NAME CONTROL ENHANCEMENT NAME  
IMPLEMENTED BY ASSURANCE

NIST SP 800-53 Rev 5 control PM-16.1 (Automated Means for Sharing Threat Intelligence) summarizes the requirements for this control: PM-16.1 · Automated Means for Sharing Threat Intelligence  
Control Statement: Employ automated mechanisms to maximize the effectiveness of sharing threat intelligence information. Supplemental Guidance: Employ automated mechanisms to maximize the effectiveness of sharing threat intelligence information. To maximize the effectiveness of monitoring, it is important to know what threat observables and indicators the sensors need to be searching for. By using well-established frameworks, services,

NIST SP 800-53 Rev 5 control PM-7.1 (Offloading) is assessed by examining, interviewing, and testing: PM-7.1 · Offloading Control Statement: Offload [organization-defined parameter] to other systems, system components, or an external provider. Supplemental Guidance: Offload [organization-defined parameter] to other systems, system components, or an external provider. Not every function or service that a system provides is essential to organizational mission or business functions. Printing or copying is an example of a non-essential but supporting service for an organization. Whenever feasible,

NIST SP 800-53 Rev 5 control PM-16 (Threat Awareness Program) summarizes the requirements for this control: PM-16 · Threat Awareness Program Control Statement: Implement a threat awareness program that includes a cross-organization information-sharing capability for threat intelligence. Supplemental Guidance: Implement a threat awareness program that includes a cross-organization information-sharing capability for threat intelligence. Because of the constantly changing and increasing sophistication of adversaries, especially the advanced persistent threat (APT), it may be more likely that adversarie

NIST SP 800-53 Rev 5 control PM-2 (Information Security Program Leadership Role) is assessed by examining, interviewing, and testing: PM-2 · Information Security Program Leadership Role Control Statement: Appoint a senior agency information security officer with the mission and resources to coordinate, develop, implement, and maintain an organization-wide information security program. Supplemental Guidance: Appoint a senior agency information security officer with the mission and resources to coordinate, develop, implement, and maintain an organization-wide information security program. The senior agency information security

NIST SP 800-53 Rev 5 control PM-28 (Risk Framing) summarizes the requirements for this control: PM-28 · Risk Framing Control Statement: a. Identify and document: 1. Assumptions affecting risk assessments, risk responses, and risk monitoring; 2. Constraints affecting risk assessments, risk responses, and risk monitoring; 3. Priorities and trade-offs considered by the organization for managing risk; and 4. Organizational risk tolerance; b. Distribute the results of risk framing activities to [organization-defined parameter] ; and c. Review and update risk framing considerations [org

Control PM-12: INSIDER THREAT PROGRAM Control: Implement an insider threat program that includes a cross-discipline insider threat incident handling team. Discussion: Organizations that handle classified information are required, under Executive Order 13587 [EO 13587] and the National Insider Threat Policy [ODNI NITP], to establish insider threat programs. The same standards and guidelines that apply to insider threat programs in classified environments can also be employed effectively to improve the security of controlled unclassified and other information in non-national security systems. Insider threat programs include controls to detect and prevent malicious insider activity through the centralized integration and analysis of both technical and nontechnical information to identify potential insider threat concerns. A senior official is designated by the department or agency head as the responsible individual to implement and provide oversight for the program. In addition to the centralized integration and analysis capability, insider threat programs require organizations to prepare department or agency insider threat policies and implementation plans, conduct host-based user monitoring of individual employee activities on government-owned classified computers, provide insider threat awareness training to employees, receive access to information from offices in the department or agency for insider threat analysis, and conduct self-assessments of department or agency insider threat posture. Insider threat programs can leverage the existence of incident handling teams that organizations may already have in place, such as computer security incident response teams. Human resources records are especially important in this effort, as there is compelling evidence to show that some types of insider crimes are often preceded by nontechnical behaviors in the workplace, including ongoing patterns of disgruntled behavior and conflicts with coworkers and other colleagues.

NIST SP 800-53 Rev 5 control PM-4 (Plan of Action and Milestones Process) summarizes the requirements for this control: PM-4 · Plan of Action and Milestones Process Control Statement: a. Implement a process to ensure that plans of action and milestones for the information security, privacy, and supply chain risk management programs and associated organizational systems: 1. Are developed and maintained; 2. Document the remedial information security, privacy, and supply chain risk management actions to adequately respond to risk to organizational operations and assets, individuals, other organizations, and the

NIST SP 800-53 Rev 5 control PM-20 (Dissemination of Privacy Program Information) is assessed by examining, interviewing, and testing: PM-20 · Dissemination of Privacy Program Information Control Statement: Maintain a central resource webpage on the organization's principal public website that serves as a central source of information about the organization's privacy program and that: a. Ensures that the public has access to information about organizational privacy activities and can communicate with its senior agency official for privacy; b. Ensures that organizational privacy practices and reports are publicly available; and

NIST SP 800-53 Rev 5 control PM-3 (Information Security and Privacy Resources) is assessed by examining, interviewing, and testing: PM-3 · Information Security and Privacy Resources Control Statement: a. Include the resources needed to implement the information security and privacy programs in capital planning and investment requests and document all exceptions to this requirement; b. Prepare documentation required for addressing information security and privacy programs in capital planning and investment requests in accordance with applicable laws, executive orders, directives, policies, regulations, standards; and c. Make

NIST SP 800-53 Rev 5 control PM-27 (Privacy Reporting) summarizes the requirements for this control: PM-27 · Privacy Reporting Control Statement: a. Develop [organization-defined parameter] and disseminate to: 1. [organization-defined parameter] to demonstrate accountability with statutory, regulatory, and policy privacy mandates; and 2. [organization-defined parameter] and other personnel with responsibility for monitoring privacy program compliance; and b. Review and update privacy reports [organization-defined parameter]. Supplemental Guidance: a. Develop [organization-defined parameter]

NIST SP 800-53 Rev 5 control PM-6 (Measures of Performance) is defined as follows: PM-6 · Measures of Performance Control Statement: Develop, monitor, and report on the results of information security and privacy measures of performance. Supplemental Guidance: Develop, monitor, and report on the results of information security and privacy measures of performance. Measures of performance are outcome-based metrics used by an organization to measure the effectiveness or efficiency of the information security and privacy programs and the controls employed in support of the program. To

facilitate security and privacy risk management, organizations consider aligning measures of

NIST SP 800-53 Rev 5 control PM-26 (Complaint Management) summarizes the requirements for this control: PM-26 · Complaint Management Control Statement: Implement a process for receiving and responding to complaints, concerns, or questions from individuals about the organizational security and privacy practices that includes: a. Mechanisms that are easy to use and readily accessible by the public; b. All information necessary for successfully filing complaints; c. Tracking mechanisms to ensure all complaints received are reviewed and addressed within [organization-defined parameter]; d. Acknowledg

NIST SP 800-53 Rev 5 control PM-12 (Insider Threat Program) summarizes the requirements for this control: PM-12 · Insider Threat Program Control Statement: Implement an insider threat program that includes a cross-discipline insider threat incident handling team. Supplemental Guidance: Implement an insider threat program that includes a cross-discipline insider threat incident handling team. Organizations that handle classified information are required, under Executive Order 13587 [EO 13587](#0af071a6-cf8e-48ee-8c82-fe91efa20f94) and the National Insider Threat Policy [ODNI NITP](#06d74ea9-2178-44

NIST SP 800-53 Rev 5 control PM-13 (Security and Privacy Workforce) summarizes the requirements for this control: PM-13 · Security and Privacy Workforce Control Statement: Establish a security and privacy workforce development and improvement program. Supplemental Guidance: Establish a security and privacy workforce development and improvement program. Security and privacy workforce development and improvement programs include defining the knowledge, skills, and abilities needed to perform security and privacy duties and tasks; developing role-based training programs for individuals assigned security and

NIST SP 800-53 Rev 5 control PM-10 (Authorization Process) summarizes the requirements for this control: PM-10 · Authorization Process Control Statement: a. Manage the security and privacy state of organizational systems and the environments in which those systems operate through authorization processes; b. Designate individuals to fulfill specific roles and responsibilities within the organizational risk management process; and c. Integrate the authorization processes into an organization-wide risk management program. Supplemental Guidance: a. Manage the security and privacy state of organizatio

NIST SP 800-53 Rev 5 control PM-28 (Risk Framing) is defined as follows: PM-28 · Risk Framing Control Statement: a. Identify and document: 1. Assumptions affecting risk assessments, risk responses, and risk monitoring; 2. Constraints affecting risk assessments, risk responses, and risk monitoring; 3. Priorities and trade-offs considered by the organization for managing risk; and 4. Organizational risk tolerance; b. Distribute the results of risk framing activities to [organization-defined parameter] ; and c. Review and update risk framing considerations [organization-defined parameter]. Supplemental Guidance: a. Identify and document: 1. Assumptions aff

PM-7.1 · Offloading Control Statement: Offload [organization-defined parameter] to other systems, system components, or an external provider. Supplemental Guidance: Offload [organization-defined parameter] to other systems, system components, or an external provider. Not every function or service that a system provides is essential to organizational mission or business functions. Printing or copying is an example of a non-essential but supporting service for an organization. Whenever feasible, such supportive but non-essential functions or services are not co-located with the functions or services that support essential mission or business functions. Maintaining such functions on the same system or system component increases the attack surface of the organization's mission-essential functions or services. Moving supportive but non-essential functions to a non-critical system, system component, or external provider can also increase efficiency by putting those functions or services under the control of individuals or providers who are subject matter experts in the functions or services.

NIST SP 800-53 Rev 5 control PM-29 (Risk Management Program Leadership Roles) is assessed by examining, interviewing, and testing: PM-29 · Risk Management Program Leadership Roles Control Statement: a. Appoint a Senior Accountable Official for Risk Management to align organizational information security and privacy management processes with strategic, operational, and budgetary

planning processes; and b. Establish a Risk Executive (function) to view and analyze risk from an organization-wide perspective and ensure management of risk is consistent across the organization. Supplemental Guidance: a. Appoint a Senior Accounta

NIST SP 800-53 Rev 5 control PM-3 (Information Security and Privacy Resources) summarizes the requirements for this control: PM-3 · Information Security and Privacy Resources Control Statement: a. Include the resources needed to implement the information security and privacy programs in capital planning and investment requests and document all exceptions to this requirement; b. Prepare documentation required for addressing information security and privacy programs in capital planning and investment requests in accordance with applicable laws, executive orders, directives, policies, regulations, standards; and c. Make

NIST SP 800-53 Rev 5 control PM-5 (System Inventory) is assessed by examining, interviewing, and testing: PM-5 · System Inventory Control Statement: Develop and update [organization-defined parameter] an inventory of organizational systems. Supplemental Guidance: Develop and update [organization-defined parameter] an inventory of organizational systems. [OMB A-130](#27847491-5ce1-4f6a-a1e4-9e483782f0ef) provides guidance on developing systems inventories and associated reporting requirements. System inventory refers to an organization-wide inventory of systems, not system components as described i